

ISG012-01 - Arquitetura de Redes Seguras Do Perímetro à Segmentação Lógica – Questões de múltipla escolha - Gabarito

Como obter maior aproveitamento deste objeto de aprendizagem:

1. Responder sem olhar o gabarito. Para isso, procurar pelas respostas nos slides da aula "ISO001-09 - Gerenciamento de memória" (teoria e prática);
1. Após responder TODAS as questões, comparar com o gabarito;
2. Refazer os passos 1 e 2 novamente com todas as questões até obter 100% de acertos de uma só vez.

Importante: Embora seja baseado nos slides teóricos e nas atividades práticas, este questionário pode conter informações que não constam nesses documentos pois pode incluir algum nível detalhamento em relação a eles. Assim, considere as informações aqui contidas como parte complementar do conteúdo a ser estudado para as provas. Todo o material distribuído pelo professor poderá ser utilizado para a confecção das questões das provas.

Teoria (14 questões)

1. Segundo o material teórico, qual é a característica principal que define uma rede plana (flat network)?

- a) Utilização de múltiplos firewalls de borda
- b) Segmentação lógica via VLANs restritas
- c) Compartilhamento do mesmo domínio de broadcast e ausência de segmentação lógica ou física
- d) Aplicação do modelo Zero Trust em todas as camadas

Resposta correta: C — O texto define redes planas como infraestruturas onde todos os dispositivos compartilham o mesmo domínio de broadcast, operando em uma única VLAN ou sub-rede, sem qualquer segmentação.

2. Qual conceito central descreve o modelo de perímetro tradicional?

- a) "Nunca confie, sempre verifique"
- b) "Hard outside, soft inside"
- c) Privilégio mínimo absoluto
- d) Microsegmentação dinâmica

Resposta correta: B — O modelo de perímetro tradicional opera sob a premissa de proteção concentrada na borda (fronteira fortificada), enquanto o interior da rede goza de confiança implícita, resumido como "Hard outside, soft inside".

3. Qual é o princípio fundamental da estratégia Defense in Depth (Defesa em Profundidade)?

- a) Nenhum controle é infalível; redundância estratégica é essencial
- b) Confiar apenas no perímetro externo como sentinela absoluta
- c) Eliminar todas as camadas intermediárias de proteção
- d) Centralizar toda a segurança em um único ponto de inspeção

Resposta correta: A — Defense in Depth emprega múltiplas camadas de controles defensivos ao longo do caminho de dados, partindo do princípio de que a falha de um único mecanismo não deve resultar em comprometimento total.

4. O paradigma Zero Trust foi desenvolvido inicialmente pelo Forrester Research e posteriormente adotado pelo NIST. Qual norma técnica do NIST define sua arquitetura?

- a) NIST SP 800-53
- b) NIST SP 800-171
- c) ISO/IEC 27001
- d) NIST SP 800-207

Resposta correta: D — O material cita especificamente a norma NIST SP 800-207 como a publicação que define a arquitetura Zero Trust.

5. A microssegmentação, no contexto de Zero Trust, pode ser definida como:

- a) A substituição completa de firewalls físicos por virtuais
- b) A divisão granular da rede em segmentos pequenos com políticas "default-deny" baseadas em identidade e contexto
- c) A utilização de uma única VLAN para todos os departamentos
- d) A centralização de logs em um servidor único da DMZ

Resposta correta: B — A nota de rodapé da pág. 13 define microssegmentação como a divisão granular em segmentos extremamente pequenos, onde políticas de acesso "default-deny" são aplicadas dinamicamente baseadas em identidade e contexto, não em endereços IP estáticos.

6. As VLANs (Virtual Local Area Networks) constituem tecnologia de qual camada do modelo OSI?

- a) Camada 1 (Física)
- b) Camada 3 (Rede)
- c) Camada 2 (Enlace de Dados)
- d) Camada 4 (Transporte)

Resposta correta: C — O texto afirma que VLANs constituem tecnologia de camada 2 do modelo OSI, permitindo a criação de domínios de broadcast lógicos independentes da topologia física.

7. Qual é a "Regra de Ouro" em relação à DMZ (Zona Desmilitarizada)?

- a) Nunca permitir conexões originadas na DMZ destinadas à rede interna
- b) Permitir que servidores da DMZ acessem diretamente a zona Management
- c) Manter todos os serviços corporativos críticos exclusivamente na DMZ
- d) Desativar todo o firewall entre a DMZ e a Internet

Resposta correta: A — A Regra de Ouro da DMZ estabelece que servidores nela alojados não podem iniciar conexões para a rede interna, apenas responder a solicitações legitimadas.

8. No contexto defensivo do subnetting, qual é um dos principais benefícios de utilizar sub-redes menores (ex: /28, /29, /30)?

- a) Aumentar o domínio de broadcast para melhorar a descoberta de serviços
- b) Eliminar a necessidade de firewalls entre segmentos
- c) Permitir que todos os hosts compartilhem a mesma tabela ARP
- d) Reduzir o escopo de varreduras e limitar o impacto de ARP spoofing

Resposta correta: D — O material destaca que subnets menores reduzem o escopo de varreduras de atacantes e limitam o impacto de ARP spoofing nos segmentos.

9. Na hierarquia de zonas de segurança apresentada, qual nível de confiança e criticidade é atribuído à zona Management?

- a) Nível 0 — Zero confiança
- b) Nível 1 — Alta exposição
- c) Nível 3 — Acesso altamente restrito
- d) Nível 2 — Usuários autenticados

Resposta correta: C — A zona Management é classificada como Nível 3, com acesso altamente restrito, monitoramento e logging intensivos.

10. O que caracteriza a arquitetura SASE (Secure Access Service Edge)?

- a) Centralização de todo o tráfego em um data center corporativo único
- b) Combinação de SD-WAN com serviços de segurança em nuvem, eliminando o backhauling centralizado
- c) Utilização exclusiva de VPNs tradicionais para acesso remoto
- d) Substituição de todas as políticas de segmentação por VLANs físicas

Resposta correta: B — SASE é definida como uma arquitetura convergida que combina SD-WAN com serviços de segurança em nuvem, aplicando políticas de segmentação e Zero Trust nos pontos de presença de borda.

11. Um Jump Host (ou Bastion Host) é melhor definido como:

- a) Um servidor hardened e fortemente monitorado em zona intermediária, usado como ponto de entrada único para acesso administrativo

- b) Um firewall de três interfaces conectado diretamente à Internet
- c) Um servidor DNS externo hospedado na DMZ
- d) Um balanceador de carga para aplicações web na camada de apresentação

Resposta correta: A — A nota de rodapé da pág. 21 define jump host como servidor hardened em zona intermediária, exigindo autenticação rigorosa e registrando todas as sessões administrativas.

12. Qual medida faz parte da prevenção contra VLAN hopping?

- a) Habilitar o trunking dinâmico (DTP) em todas as portas
- b) Compartilhar a VLAN nativa entre todos os switches sem restrições
- c) Permitir que qualquer porta negocie automaticamente modo trunk
- d) Desativar o trunking dinâmico e configurar explicitamente portas como access ou trunk

Resposta correta: D — O material cita como hardening a desativação do trunking dinâmico (DTP), configuração explícita de portas e isolamento da VLAN nativa.

13. O backhauling de tráfego é definido como:

- a) A distribuição automática de políticas de segurança via SD-WAN
- b) A criação de túneis criptografados diretos entre filiais (topologia mesh)
- c) A prática de direcionar todo o tráfego por um ponto centralizado antes do destino final
- d) A substituição de firewalls físicos por serviços cloud-native

Resposta correta: C — A nota de rodapé da pág. 23 define backhauling como a prática de direcionar todo o tráfego através de um ponto centralizado (geralmente o data center corporativo) para inspeção de segurança.

14. Infraestrutura como Código (IaC) é a prática de:

- a) Escrever software exclusivamente para automação de backups
- b) Gerenciar e provisionar recursos de infraestrutura através de arquivos de configuração versionáveis e automatizáveis
- c) Substituir completamente os administradores de rede por inteligência artificial
- d) Criar diagramas de rede manualmente em papel para auditoria

Resposta correta: B — A nota de rodapé da pág. 26 define IaC como a prática de gerenciar servidores, redes e firewalls através de arquivos de configuração versionáveis, garantindo consistência e auditoria.

Prática (6 questões)

15. No laboratório prático, qual é o endereço IP configurado na interface eth2 (DMZ) do Linux Mint Gateway?

- a) 192.168.1.1/24
- b) 192.168.3.1/24
- c) 10.0.0.1/24
- d) 172.16.0.1/24

Resposta correta: D — A topologia do laboratório e o arquivo netplan indicam que eth2 (DMZ) possui o endereço 172.16.0.1/24.

16. Qual comando habilita o IP forwarding temporariamente no Linux Mint Gateway?

- a) `sudo sysctl -w net.ipv4.ip_forward=1`
- b) `sudo echo 1 > /etc/sysctl.conf`
- c) `sudo iptables --enable-forwarding`
- d) `sudo route add default gw 172.16.0.1`

Resposta correta: A — O material apresenta o comando `sudo sysctl -w net.ipv4.ip_forward=1` para habilitação temporária do encaminhamento de pacotes.

17. Qual é o arquivo de configuração do Netplan utilizado para definir as interfaces do gateway?

- a) `/etc/network/interfaces`
- b) `/etc/dhcp/dhcpd.conf`

- c) /etc/netplan/01-netcfg.yaml
- d) /etc/resolv.conf

Resposta correta: C — O laboratório utiliza o arquivo /etc/netplan/01-netcfg.yaml para declarar as 4 interfaces de rede e suas respectivas zonas.

18. Qual é a regra nftables que implementa o bloqueio crítico do tráfego da DMZ para a Management?

- a) sudo nft add rule inet filter forward ip saddr 192.168.1.0/24 ip daddr 172.16.0.0/24 drop
- b) sudo nft add rule inet filter forward ip saddr 172.16.0.0/24 ip daddr 192.168.3.0/24 drop
- c) sudo nft add rule inet filter input tcp dport 22 drop
- d) sudo nft add rule inet filter output ip daddr 192.168.3.0/24 accept

Resposta correta: B — A regra crítica bloqueia pacotes com origem na DMZ (172.16.0.0/24) e destino à Management (192.168.3.0/24), conforme script de firewall.

19. Na configuração do VirtualBox, qual faixa de rede IP é utilizada pela VM External (Windows 10) que simula um atacante?

- a) 10.0.0.0/24
- b) 192.168.1.0/24
- c) 172.16.0.0/24
- d) 192.168.3.0/24

Resposta correta: A — A VM External utiliza adaptador NAT isolado e recebe IP na faixa 10.0.0.x/24 via DHCP, não acessando as zonas internas.

20. Para adicionar uma rota persistente no Windows (VM Internal) apontando para a rede DMZ via gateway Linux, qual parâmetro é essencial no comando route add?

- a) -f
- b) -n
- c) -g
- d) -p

Resposta correta: D — O parâmetro -p torna a rota persistente, mantendo-a após o reboot do sistema Windows.